

T3 Evidence Check: Human-in-the-Loop

Each claim in the two editions, traced to the experiment and the recorded evidence behind it, with a status: supported, qualified, contradicted or not tested.

T3

T3 · Production AI Engineering

7 min read · Published 2026-10-03 · Evidence Check

01 • The question we tested

How do we pause an autonomous action, obtain an accountable decision from an authorized human, bind it to exactly what was reviewed, and resume without stale authority or stale world state? The POC answers by running the same production incident through three approval protocols and trying to break each one, 30 ways.

02 • What ran

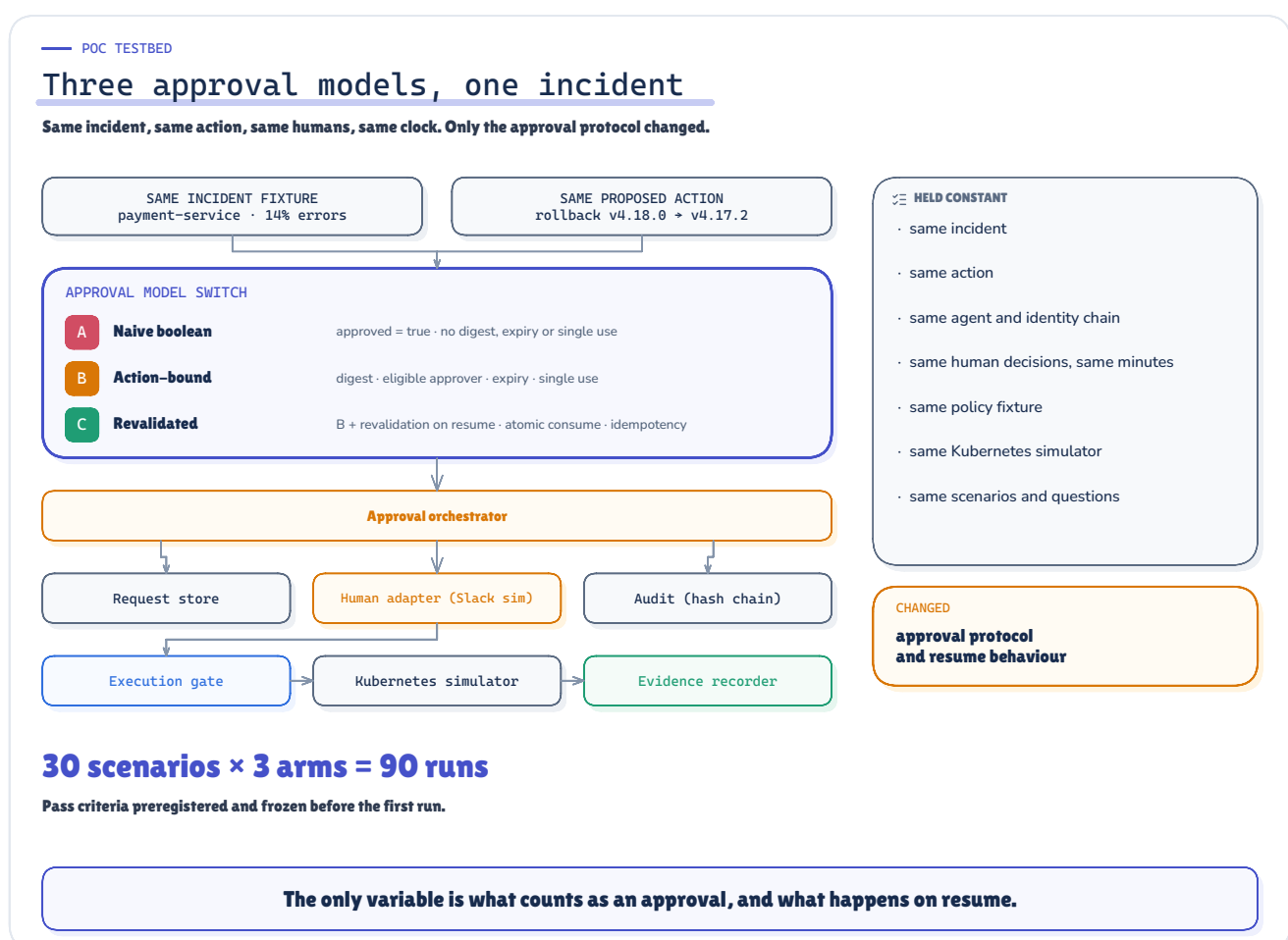


Figure 1. The testbed: one incident, three approval protocols, everything else held constant.
Implemented + measured: the testbed of hitl_poc; counts from the run · run 2026-10-03-protocol

The approval protocol code is real: the approval artifact, digest binding, eligibility and separation of duties, quorum, expiry, single-use consumption, revalidation, idempotency keys, the state machine and the hash-chained audit. Datadog, Kubernetes, Slack, the identity provider, the humans and the clock are simulated and deterministic. Real vs simulated itemises the split. Every observed value is in the Run Report.

03 · Method

Held constant. The incident (payment-service at 14% errors after `v4.18.0`), the proposed action (`rollbackDeployment v4.18.0 → v4.17.2`), the agent and its identity chain, the policy fixture (prod-change-policy v7, or v8 where a scenario changes it), the simulated Kubernetes, the human decisions and the minutes at which they happen, the workflow inputs, the scenarios and the 16 evidence questions.

The only variable. The approval protocol and its resume behaviour: **A** naive boolean (`approved = true`), **B** action-bound approval artifact (digest, eligible approver, expiry, single use marked after the call), **C** revalidated protocol (B plus atomic consume, revalidation of identity, delegation, policy, resource state and approver on resume, an idempotency key, a credential minted after revalidation).

Preregistered and frozen. The arms, the 30 scenarios with their oracles (which resume may legitimately write, which decision is ineligible), the metric definitions, 8 fixed global assertions and every hypothesis were written in `proof/preregistration.toml`. The 79 checks were generated from it, and both were frozen with `hitl freeze` before the first scenario ran. The freeze timestamp and the hash of every frozen file are in the run manifest. A run refuses to start if a frozen file changed.

Deviations. Three changes were made after the freeze, all logged in `proof/DEVIATIONS.md` and copied into the run. (1) The fact builder did not compute the per-experiment class metrics that H8's hypotheses name, so the first run stopped before writing anything; the builder was fixed. (2) A code review against the preregistered arm definition ("C is everything in B, plus revalidation") found that C's gate lacked B's request-binding check. In the recorded run C had refused both cross-workflow replays only because the approval was already consumed. The check was added. (3) The proof contract's schema rejected the first ids, so experiments and checks were renamed to its pattern (H is T3-R, GA is T3-R10, CS is T3-R11, API is T3-R12) and the checks file was re-frozen. Each check keeps a readable label (`H5-B01`: H5, arm B, prediction 1), and this page uses the labels. None of the three changes altered a scenario, an oracle, a metric or a check outcome.

04 · Results at a glance

TECH · SCORECARD

H1-H9 under the three arms

The headline metric of each experiment, per arm, and its preregistered checks.

		ARM A	ARM B	ARM C	CHECKS
H1 Exact action binding	executions	1	0	0	3 pass · 1 exp. fail · 0 fail
H2 Mutation after approval	executions	3	0	0	4 pass · 1 exp. fail · 0 fail
H3 Approval replay	replays	3	0	0	3 pass · 1 exp. fail · 0 fail
H4 Approver eligibility	acceptances	4	0	0	4 pass · 1 exp. fail · 0 fail
H5 Stale world state	stale resumes	3	3	0	2 pass · 1 exp. fail · 0 fail
H6 Identity or policy change	stale resumes	4	4	0	2 pass · 1 exp. fail · 0 fail
H7 Duplicate resume	duplicates	4	2	0	4 pass · 1 exp. fail · 0 fail
H8 Deny, expiry, escalation	executions	2	0	0	5 pass · 1 exp. fail · 0 fail
H9 Audit reconstruction	of 16 answered	10	15	16	3 pass · 1 exp. fail · 0 fail
ALL 30 SCENARIOS · unauthorized executions		26	9	0	

79 checks: 70 pass · 9 expected failures (arm A, the control) · 0 fail

Figure 2. The headline metric of each experiment under the three arms, read from the run.
Measured: headline metric per experiment and arm; checks.jsonl · run 2026-10-03-protocol

Fixed global assertion (must be 0 under C)	A	B	C
unauthorized executions	26	9	0
mutated-action bypasses	4	0	0
successful approval replays	3	0	0
duplicate external side effects	4	2	0
expired approval executions	2	0	0
ineligible approver acceptances	4	0	0
silent stale-context resumes	7	7	0
audit reconstruction gaps	36	19	0
legitimate executions (not a criterion; for scale)	10	10	10

Of 79 checks, 70 passed, 9 were arm A's controls breaking as predicted, and 0 failed. 0 hypotheses were not supported.

05 • Claim → evidence

Status. **Supported:** the recorded run shows it and a frozen check asserts it. **Qualified:** the run shows it holds only within a stated bound. **Contradicted:** a preregistered hypothesis failed. **Not tested:** the POC was not built to show it. Paths are relative to `hitl_poc/evidence/runs/2026-10-03-protocol/`.

#	Claim	Experiment	Evidence path	Status	Notes
1	A boolean approval acts as ambient permission.	H1-H9, arm A	<code>raw/scenarios/*/A/</code> ; checks H1-A01 ... H9-A01	Supported	By construction: A is the control. 26 unauthorized executions across the run
2	Binding an approval to an action digest stops a different or mutated action.	H1, H2	<code>raw/scenarios/H1*</code> , <code>H2*</code> ; H1-B01, H1-C01, H2-B01, H2-C01	Supported	0 bypasses under B and 0 under C; C opened 3 new requests in H2
3	An approval cannot turn a policy DENY into ALLOW.	H1b, CS-T05	<code>raw/scenarios/H1b/*/</code> ; H1-A02	Supported	Only because policy is enforced on every call, in every arm (0 writes even under A)
4	Request binding and single use stop replays, even of an identical action.	H3	<code>raw/scenarios/H3*</code> ; H3-B01, H3-C01, H3-C02	Supported	0 replays under C; the legitimate first execution still ran (3)
5	Only an authenticated, eligible, independent human can approve; a two-person rule needs two distinct approvers.	H4	<code>raw/scenarios/H4*</code> ; H4-B01, H4-C01, H4-C02, H4-C03	Supported	0 ineligible acceptances under C, 4 under A
6	Binding is not revalidation: an action-bound, unexpired approval still resumes against a changed context.	H5, H6	<code>raw/scenarios/H5*/B/</code> , <code>H6*/B/</code> ; H5-B01, H6-B01	Supported	7 stale resumes under B
7	Revalidation on resume stops stale resumes: world, identity, delegation, policy, approver.	H5, H6	<code>raw/scenarios/H5*/C/</code> , <code>H6*/C/</code> ; H5-C01, H6-C01, GA-07	Supported	0 under C; each stopped with a named reason
8	One approval produces at most one side effect only if consumption is atomic and recorded before the call.	H7	<code>raw/scenarios/H7*</code> ; H7-B01, H7-B02, H7-C01, H7-C02, GA-04	Supported	B duplicated 2 times on a crash or a race, 0 on clicks and webhooks; C 0
9	Deny and silence never execute; expiry stops late approvals; escalation is a recorded transition.	H8	<code>raw/scenarios/H8*</code> ; H8-A01, H8-B01, H8-C01, H8-C02, H8-C03	Supported	Even A never executed after a deny or silence (0); A executed 2 expired approvals

#	Claim	Experiment	Evidence path	Status	Notes
10	C's records reconstruct every executed privileged action.	H9	<code>raw/scenarios/H9a/*/scenario.json</code> → reconstruction; H9-C01, H9-C02, GA-08	Supported	16/16 under C, 15 under B, 10 under A; 0 gaps over 10 writes
11	C held every fixed global assertion while executing every legitimate action.	all	<code>experiments.json</code> → <code>arms.C.global</code> ; GA-01 ... GA-08	Supported	10 legitimate executions, the same as A and B
12	Revalidation re-checks the action and the authority, not every fact the human saw.	H5c	<code>story.json</code> → <code>not_revalidated</code>	Qualified	Severity rose SEV2 → SEV1 during the pause; no check covered it (1)
13	Expiry protects against stale approvals.	H5, H6	<code>raw/scenarios/H5*/B/</code> , <code>H6*/B/</code>	Qualified	It bounds staleness; it does not detect it. Every stale approval arrived inside its 60-minute expiry
14	Crash recovery is exactly-once.	H7c	<code>raw/scenarios/H7c/C/</code>	Qualified	Only because the simulated Kubernetes honours an idempotency key (RECONCILED); real Kubernetes has none
15	B's duplicates were harmless.	H7c, H7d	<code>raw/scenarios/H7c/B/</code> , <code>H7d/B/</code>	Qualified	2 and 2 writes, 1 and 1 state changes: the target was already running. A non-idempotent action would not be absorbed (reasoned)
16	Requiring a human approval reduces the risk of an autonomous action.	H5, H6	<code>raw/scenarios/H5*/B/</code> , <code>H6*/B/</code>	Qualified	Humans approved 7 requests whose context had changed; only revalidation stopped them
17	Nothing can change between the last revalidation check and the write.	none	none	Not tested	Revalidation and the write ran in one synchronous step; CWE-367 ^[18]
18	A better evidence card produces better human decisions.	none	none	Not tested	The humans are scripted

#	Claim	Experiment	Evidence path	Status	Notes
19	The protocol holds with real Slack, a real IdP, a real cluster and a durable workflow engine.	none	none	Not tested	All simulated
20	The approval path is fast and available enough for incident response.	none	none	Not tested	No latency or availability measured
21	The same boundary holds test by test and through the real HTTP surface.	CS, API	<code>test-report.json</code> , <code>raw/api.json</code> ; CS-*, API-01, API-02	Supported (implementation)	30/30 conformance tests; 9/9 HTTP calls as expected, 1 rollback

Contradicted: none. No preregistered hypothesis failed. Every prediction about arm B held, including the ones that predicted it would break. That says something about this design and these scenarios. It is not a measurement of how often such failures happen in the world.

06 · What the POC qualified

MEASURED

REASONED

from H5c, H5, H6 and H7; each bound is stated

- **Revalidation is only as wide as its checks.** C re-checked identity, runtime, delegation, expiry, digest, policy version and requirement, resource state and approver eligibility. The severity shown on the card was not among them, and it changed.
- **Expiry is a bound, not a detector.** A 60-minute expiry let a 37-minute-old approval through under B every time. Shortening it narrows the window and adds expired requests. It does not tell you the world changed.
- **Exactly-once leaned on the simulator.** C reconciled the crashed attempt by calling Kubernetes again with the approval's idempotency key. Real Kubernetes has no such key, so a production gateway must reconcile by reading the rollout's state.
- **Absorbed is not prevented.** B's duplicate rollbacks changed nothing only because the target version was already running. A restart, a payment or a ticket would have happened twice.
- **A human is not a safety guarantee.** In the stale scenarios, eligible humans approved requests whose context had changed. The control that caught them was deterministic revalidation, not the person.

07 · What this evidence does not show

- **The check-to-write window.** Revalidation and the write ran in one synchronous step. A change landing between them was not injected (CWE-367 ^[18]).
- **Real integrations.** Slack interactivity and signing, an enterprise IdP, a real cluster and a durable workflow engine are simulated. A pause is a clock advance.
- **Human behaviour.** The clicks are scripted. Nothing here measures rubber-stamping, alert fatigue or whether a better card changes decisions ^[34].
- **Performance and availability.** Nothing measures the latency or the availability of the approval path.
- **One deterministic run.** Repetition adds no statistical weight; the evidence is the frozen checks, not a distribution.

08 · Reproduce and verify

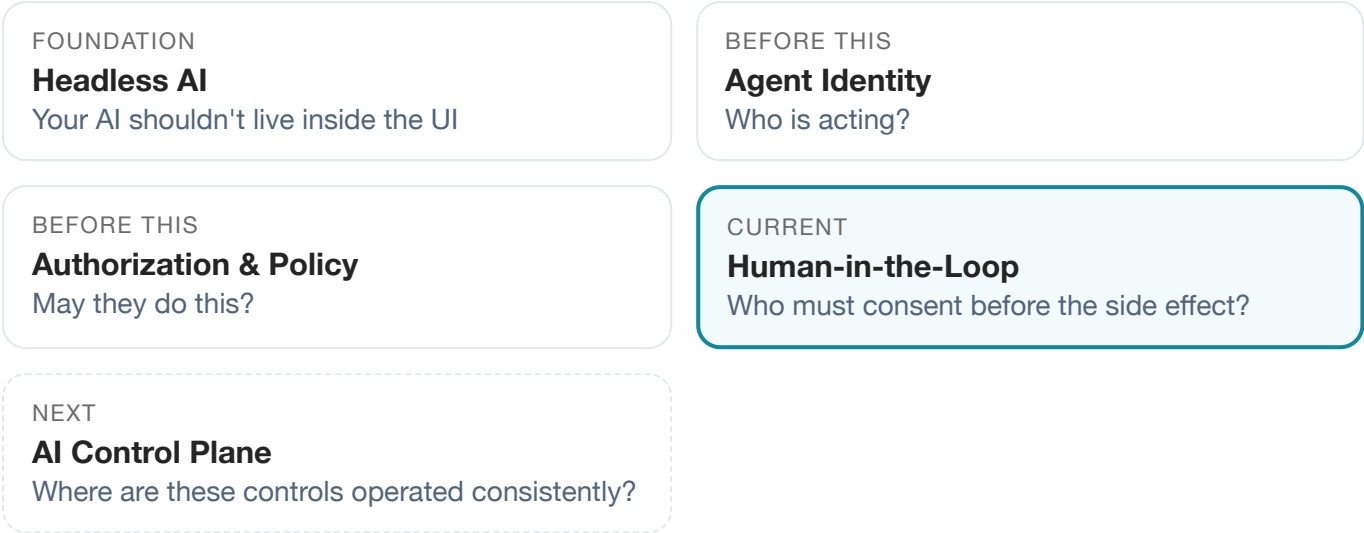
```
cd hitl_poc && uv sync --group dev
uv run pytest                                # conformance, unit and H1-H9 tests
uv run hitl proof --run-id 2026-10-03-protocol # refuses to run if a frozen file changed
uv run hitl verify 2026-10-03-protocol        # schemas, freeze, replay byte for byte,
integrity, claims
uv run hitl scenarios H5c                     # the opening story under A, B and C
```

Evidence

Claims

Human-in-the-Loop

PRODUCTION AI ENGINEERING · FOUNDATION TRACK



The full learning map (Start Here)

T3 · Production AI Engineering

Production AI Engineering · T3 · Evidence. Every measured number here is substituted at build time from `hitl_poc/evidence/runs/2026-10-03-protocol/results.json` (Proof Contract v1); the enterprise systems are simulated and the run is deterministic. Figures carry their provenance.

- Medium edition
- Technical deep dive
- POC README
- Run summary
- Proof verification
- QA report